Access control

How permissions work in BienSync: how they used to work, how they work now, and what changed.

Branch `superadmin-ui-2` · 31 October 2026

> **Where the code lives**
> - Module list: `src/config/permissions.ts`
> - Rules (ceiling, cascade, team checks): `src/services/access.ts`
> - Pure grid helpers: `src/lib/permission-grid.ts`
> - Grid UI: `src/components/platform/permissions-form.tsx`

0. How the logic worked before

Each user could have `UserPermission` rows: one per module, with View / Create / Edit / Delete flags. But:

- **Only Staff were checked.** Admins and the SuperAdmin skipped every permission check, so an Admin had full access to their clinic.
- **Only Appointments was enforced.** No other module checked permissions; Staff were simply blocked from Patients.
- **Module names were free text and case-sensitive.** A row saved as `"appointments"` instead of `"Appointments"` silently matched nothing.
- **Create / Edit / Delete didn't require View.** Staff could be given "delete" without "view".
- **Admins could only create Staff, never Admins** (`POST /api/admin/users` was locked to the Staff role), and could only edit or delete Staff in their clinic.
- **No limit on what could be given away**, and **no record of who created whom**, so removed access couldn't follow down a chain.
- **No screen to manage access.** Permissions could only be set through the API.
- **A hidden Prisma bug:** `.where(...).delete()` / `.update()` change only one matching row, so clinic, patient and user deletes, and the permission replace, left rows behind.

1. How the logic works now

The grid

Every Admin and Staff member has a grid: one row per module, with four switches: **View / Create / Edit / Delete**.

- **Clinic work modules:** Appointments, Patients, Doctors, Messages, Reviews, Finances.
- **Team management modules:** Staff, Admins.

- **Fixed list:** module names come from `src/config/permissions.ts`. The API rejects any other name, so a typo can't silently block someone.
- **View is automatic:** turning on Create, Edit or Delete also turns on View. Turning View off clears the whole row.
- **Storage:** a module with nothing switched on has no row in `UserPermission`.

The four rules

Every route that changes access goes through `applyAccessChange`, and team actions are gated by `checkTeamAccess` (both in `src/services/access.ts`).

1. **Only the SuperAdmin skips the checks.** Admins are checked like Staff.
2. **No passing on more than you have (the ceiling).** An Admin can only *add* access they hold themselves. Access a person already has, for example something the SuperAdmin gave them, can be kept or removed. In the grid, boxes the Admin can't give are greyed out.
3. **Removing access goes down the chain (the cascade).** `User.created_by_id` records who created each user. When access is removed from someone, it's also removed from everyone they created, at every level below.
4. **Starting access.**
   - Admin created by the SuperAdmin → full access.
   - Admin created by another Admin → exactly that Admin's access.
   - New Staff → nothing until someone grants it.

Other limits

- Staff can never hold the Staff or Admins modules (the API returns 400).
- Admins can't change their own access, and can't change anyone's role.
- Admins only see and manage people in their own clinic.
- Permissions are read from the database on every request, so changes apply immediately.

2. What each role can do

Role	Can do
SuperAdmin	Everything, everywhere. Creates clinics and users, and sets any Admin's or Staff member's access from **Users** → **Access**. Never restricted.
Admin	Only what their grid allows, in their own clinic. Manages people through the **Staff** and **Admins** modules (table below). Can't change their own access or anyone's role, and can't grant more than they have. Works from the **Team** page.
Staff	Only what their grid allows. Can never hold the Staff or Admins modules, so can't manage people.

Team management switches (Admins only)

Switch	On the Staff module	On the Admins module
View	See staff on the Team page	See other Admins on the Team page
Create	Add new staff	Add new Admins
Edit	Edit staff details and their access	Edit other Admins' details and access
Delete	Remove staff	Remove other Admins

The **Team** link in the clinic sidebar only shows for Admins who can view Staff or Admins.

What the API actually checks today

Module	Checked by the API?
Appointments, Staff, Admins	Yes
Patients, Doctors, Messages, Reviews, Finances	Not yet The switches save, but nothing checks them (the grid shows a "Not enforced yet" badge).

Staff are still blocked from Patients completely, whatever their switches say.

3. Database changes

All applied to the **local** database (`localhost`) only.

New column: `User.created_by_id`

- Nullable text column plus an index, added in `src/prisma/contract.prisma`.
- Applied with `prisma db update`: only two additive operations ran (add column, create index). No data was lost.
- When a user is deleted, the users they created are handed to the deleted user's own creator, so the chain stays connected.
- On another database: `npm run db:update`.

Backfill: existing Admins keep full access

- Script: `src/prisma/backfill-admin-access.ts`. It gives every Admin with **no** permission rows full access; Admins who already have rows are skipped, so it's safe to run more than once.
- Already run locally (updated dr.smith@clinic.com).

> On another database, run it once or its Admins will lose access:
> `npx tsx src/prisma/backfill-admin-access.ts`

Bug fix: Prisma bulk writes

In this Prisma 8 version, `.where(...).delete()` and `.where(...).update()` change **only one** matching row. Clinic delete, patient delete, user delete and permission save were all leaving rows behind. 18 repository calls were switched to `deleteAndCount()` / `updateAndCount()`. Calls that target one row by `id` were left as they were.

4. What changed

Core

File	Change
`src/config/permissions.ts`	New. Fixed module list, action labels, grid types.
`src/services/access.ts`	New. `getGrid`, `can`, `applyAccessChange`, `checkTeamAccess`.
`src/lib/permission-grid.ts`	New. Pure grid math, shared by the API and the pages.
`src/types/permissions.ts`	Module names must be in the list; View is implied.
`src/services/api-guard.ts`	`checkModulePermission` applies to Admins too.

API

Route	Change
`/api/users/[id]/permissions` and `/[permissionId]`	All go through `applyAccessChange`. PATCH no longer allows Create/Edit/Delete without View.
`POST /api/admin/users`	Admins create Staff or Admins in their clinic, gated by the Create switch. Sets `created_by_id`.
`POST /api/users`	Sets `created_by_id`; a new Admin gets full access.
`GET /api/users` (Admin)	Returns only the roles they may view, excluding themselves.
`PATCH` / `DELETE /api/users/[id]` (Admin)	Gated by the Edit/Delete switches; no role changes.
`/api/appointments/*`	Admins are checked as well as Staff.

Pages

Page	Change
`/platform/users/[id]/access`	Access grid for Admins and Staff.
`/platform/users`	**Access** button for Admins and Staff.
`/team`, `/team/new`, `/team/[id]/edit`, `/team/[id]/access`	New. An Admin's team list, add, edit and access pages. Buttons follow their permissions.
Clinic sidebar	**Team** link for Admins who can view Staff or Admins.

Skills

- `clinic-code-architecture`: access rules and the Prisma bulk-write pitfall.
- `clinic-ui-design`: new icons in the icon table.

5. Not done yet

- **Existing Staff** have no recorded creator, so removing access from an Admin doesn't reach Staff created before this change.
- **Role changes** (Staff to Admin or back) are only possible on the platform pages, by the SuperAdmin.
- **Unchecked modules:** Patients, Doctors, Messages, Reviews and Finances still need permission checks in their API routes.
- **Testing:** the rules passed 14 checks against the local database; the pages haven't been clicked through in a browser yet.
- **Not committed.** Include the `migrations/` files that `db update` wrote.